



Practical ICS/OT Defense

Offense & Defense from a Controls Engineering perspective

 by Neil Brandon

Agenda



The roots of ICS/OT insecurity.

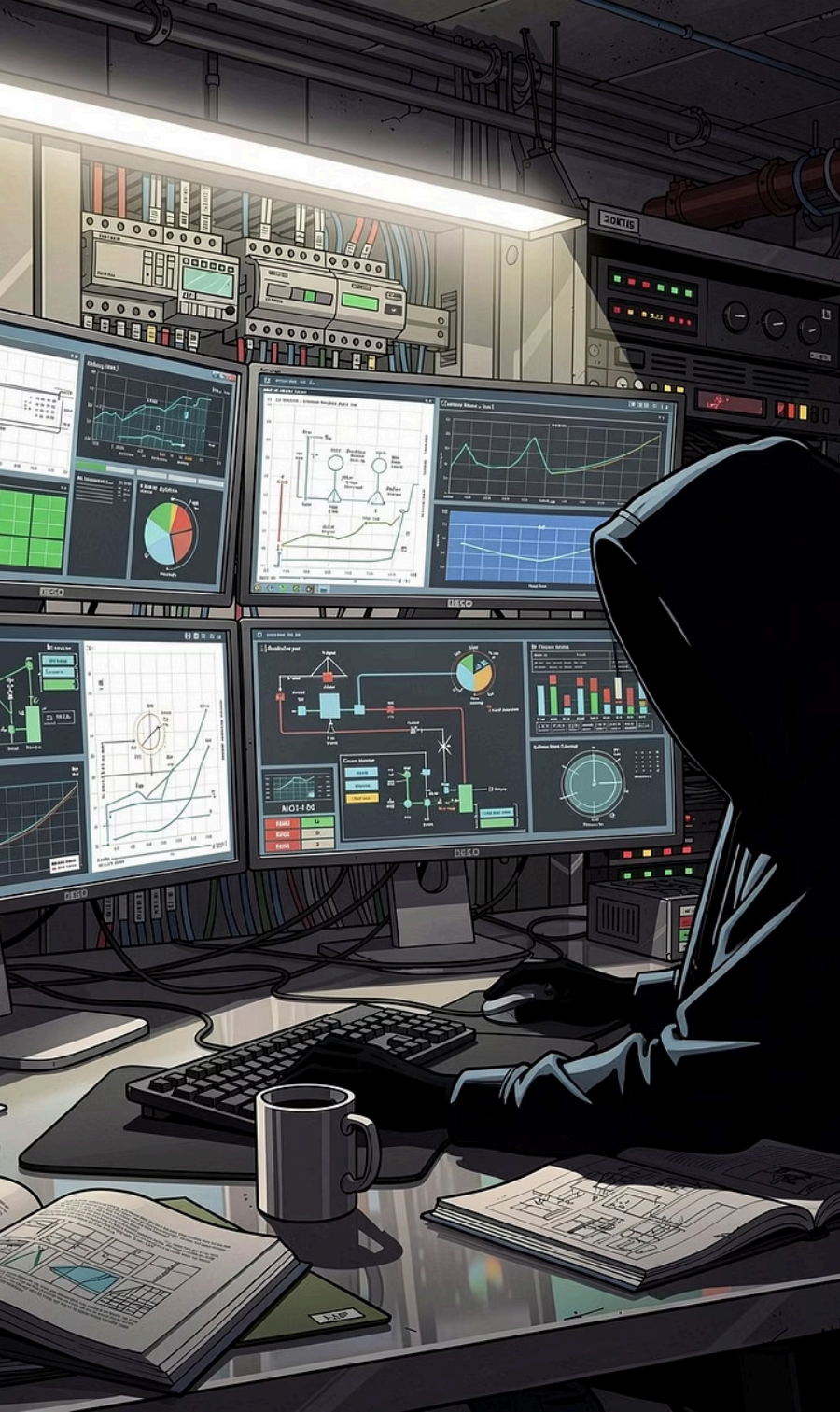


Thinking like an adversary.

(FrostyGoop Example)



Where do we go from here?



YOUR SPEAKER

Neil Brandon

ICS Village · Hardware Builder, 5 years in ICS/OT cybersecurity

Faith Technologies - Principal Engineer - DC Team, 20 years controls engineer

Certifications: GICSP · GRID · GCIP · Security+

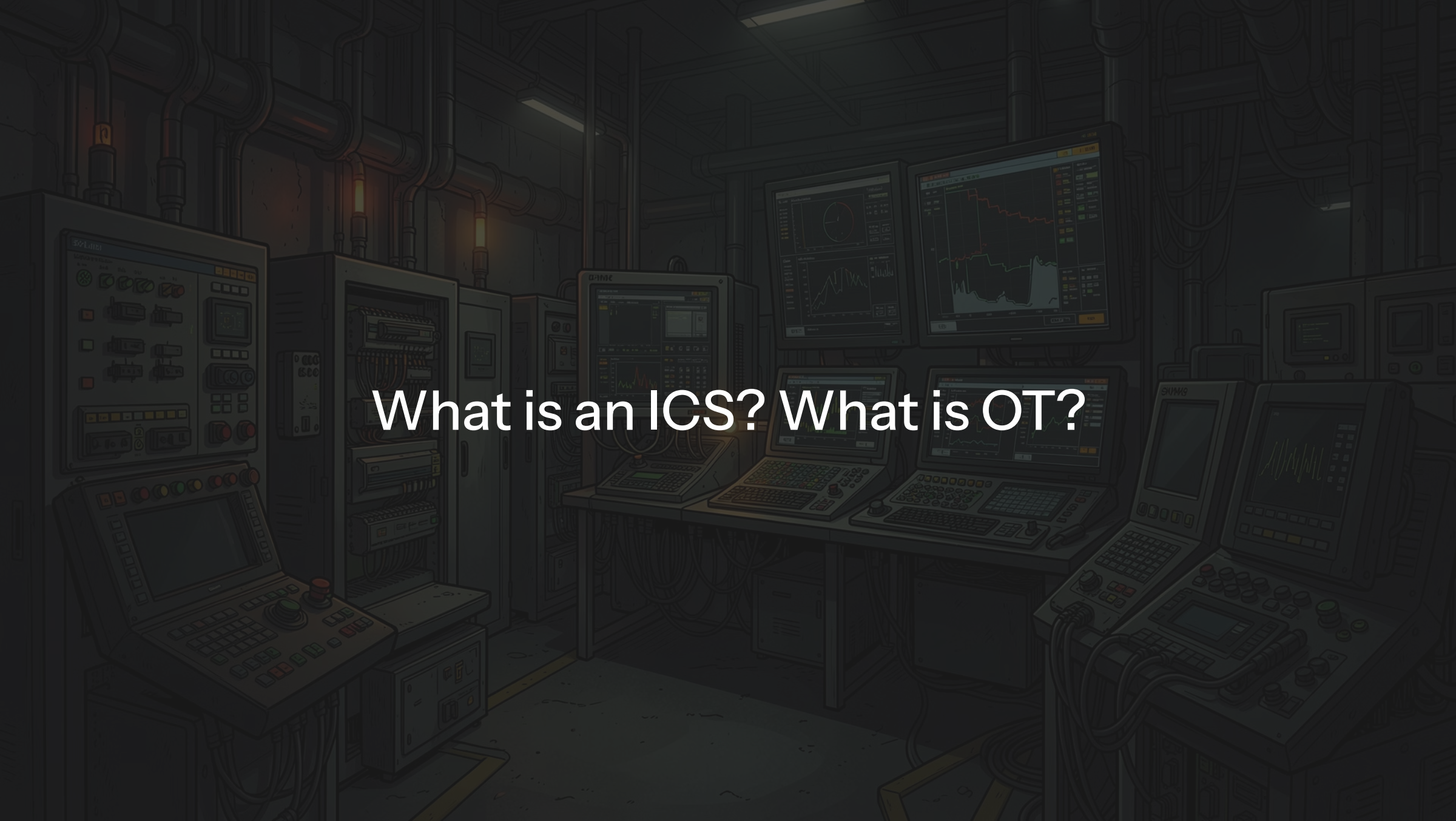
📌 Feel free to ask questions during the talk!

You'll walk away able to:

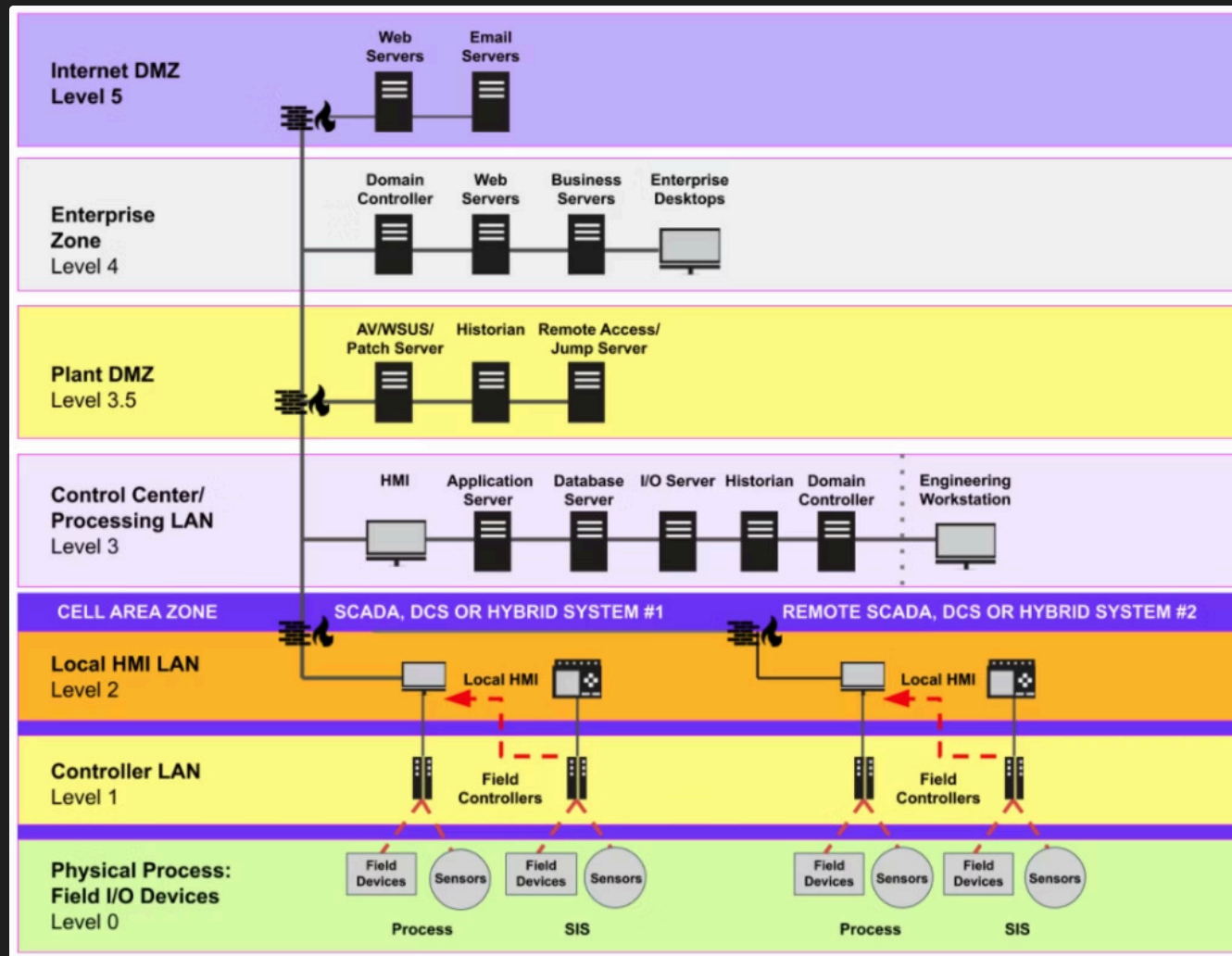
- Understand the history surrounding ICS/OT.
- Walk through FrostGoop through the eyes of a TA and Defender.
- Understanding some of the challenges around ICS/OT.

Find me after the session on **LinkedIn**. (What do people use nowadays?)

Published at: https://github.com/NeilBrandon/Grassr00tz_2026



What is an ICS? What is OT?



Purdue Reference Architecture (PERA)

Thanks Claroty!

Sizes vary and does not define impact!



The Roots of OT Insecurity

Industrial Control Systems (ICS) and Operational Technology (OT) environments were not initially designed with modern cybersecurity in mind. Their fundamental architecture, legacy components, and historical evolution have created a uniquely challenging security landscape.

Production Over Security

Original design prioritized operational continuity, physical safety, and reliability. Cybersecurity was an afterthought, leading to inherent vulnerabilities.

The "Air-Gapped" Myth

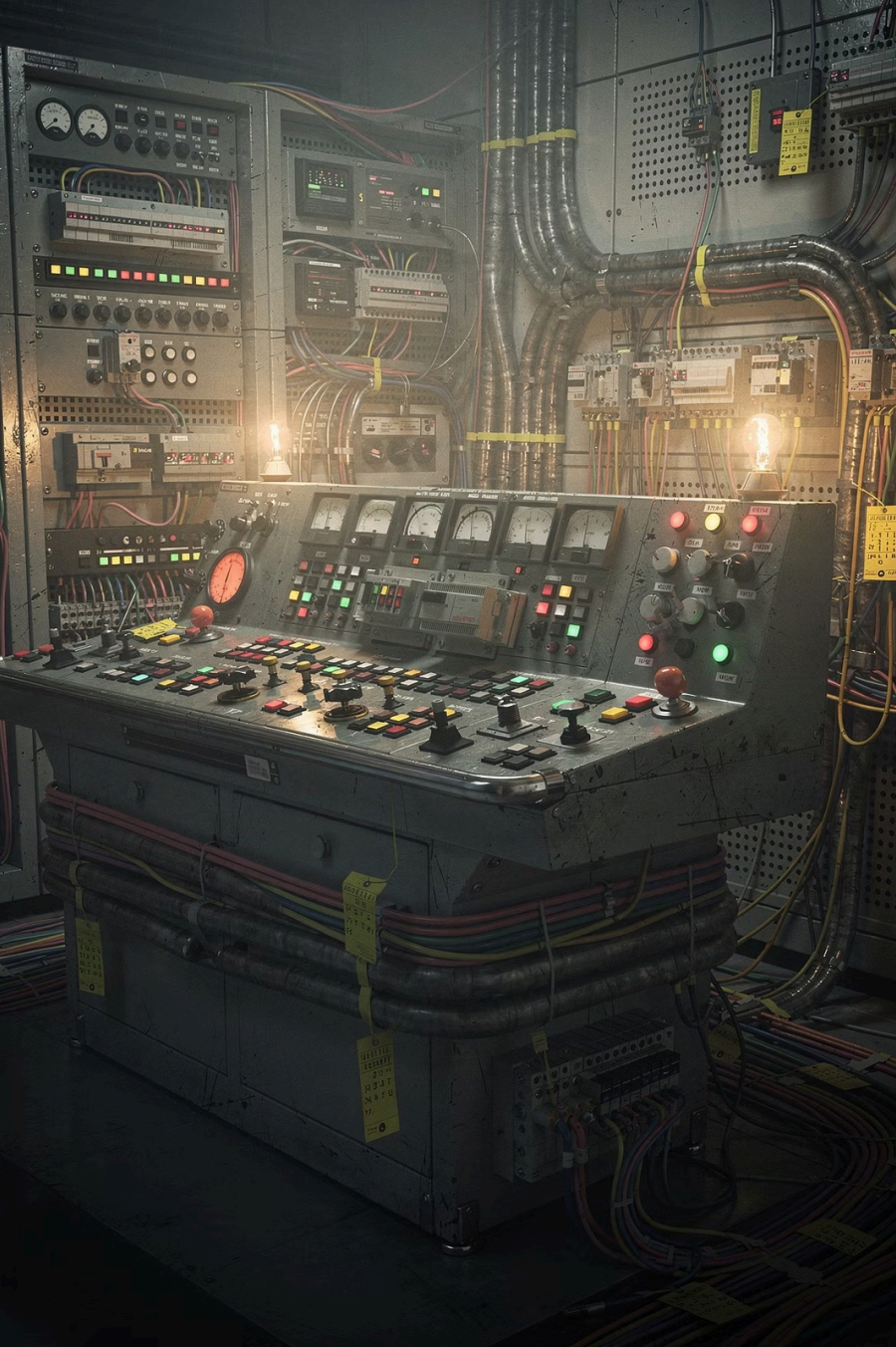
Once isolated, OT networks are now increasingly connected to corporate IT, supply chains, and the internet, opening pathways for cyber threats.

Legacy Infrastructure

Long operational lifespans mean systems designed in the 70s and 80s, lacking modern security features, are still in use today.

Proprietary Protocols

Many OT protocols (like Modbus, DNP3, Profibus, HART, EtherNet/IP) were developed without built-in security, making them vulnerable to eavesdropping and manipulation.

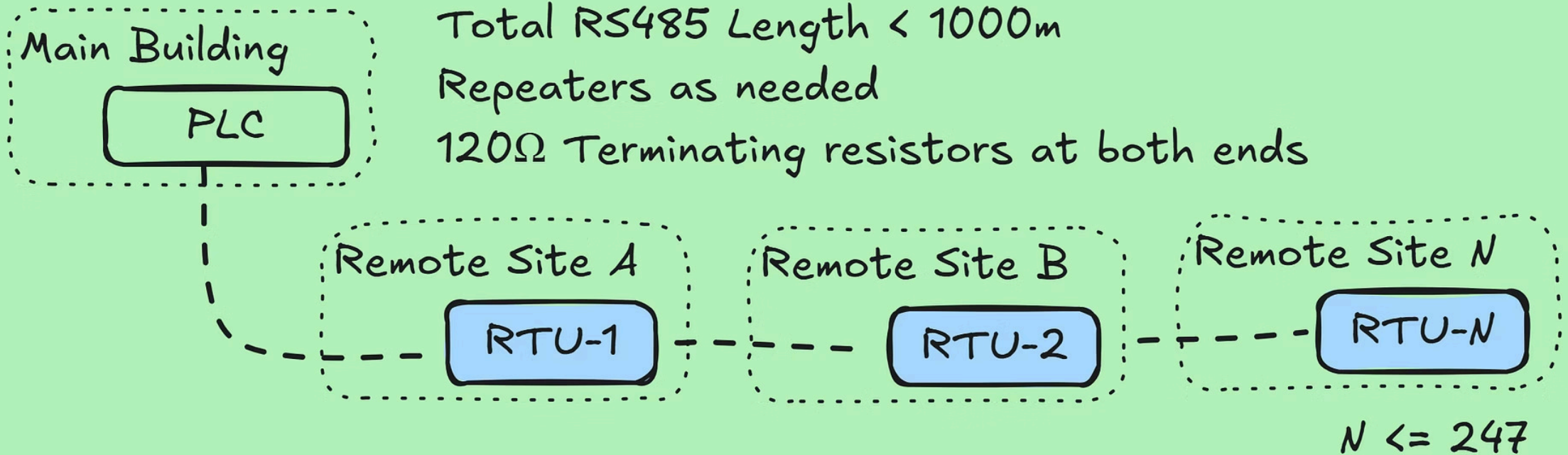


The 70s through the 90s: Birth of Automation

The 1970s through the 1990s saw PLCs become standard in industry. Most proprietary protocols were built for reliability on closed networks, with security as a lower priority.

- **Data Highway, DH+:** Rockwell Automation protocol.
- **Modbus RTU:** Early Modicon protocol.
- **HART:** Rosemount protocol for field devices.
- **DNP3:** Westronic protocol for utilities and control systems.

Modbus RTU (Serial) 1970s-1990s





The 2000s through 2010s: IT/OT Convergence

OT systems increasingly connected with IT networks for efficiency and remote access.

Ethernet Comes to OT

Ethernet enabled legacy OT protocols to run over standard networks.

Blurred Boundaries

OT assets became reachable from corporate networks, expanding the attack surface.

Commercial Technologies

OT adopted standard IT tools, bringing familiar security risks with them.

ICS/OT, a story of vendor lock

ICS/OT assets vary widely in criticality and risk.

Vendor Lock-in Strategies

Many proprietary ICS/OT protocols are designed to tie organizations to specific vendor ecosystems.

Implications for Security

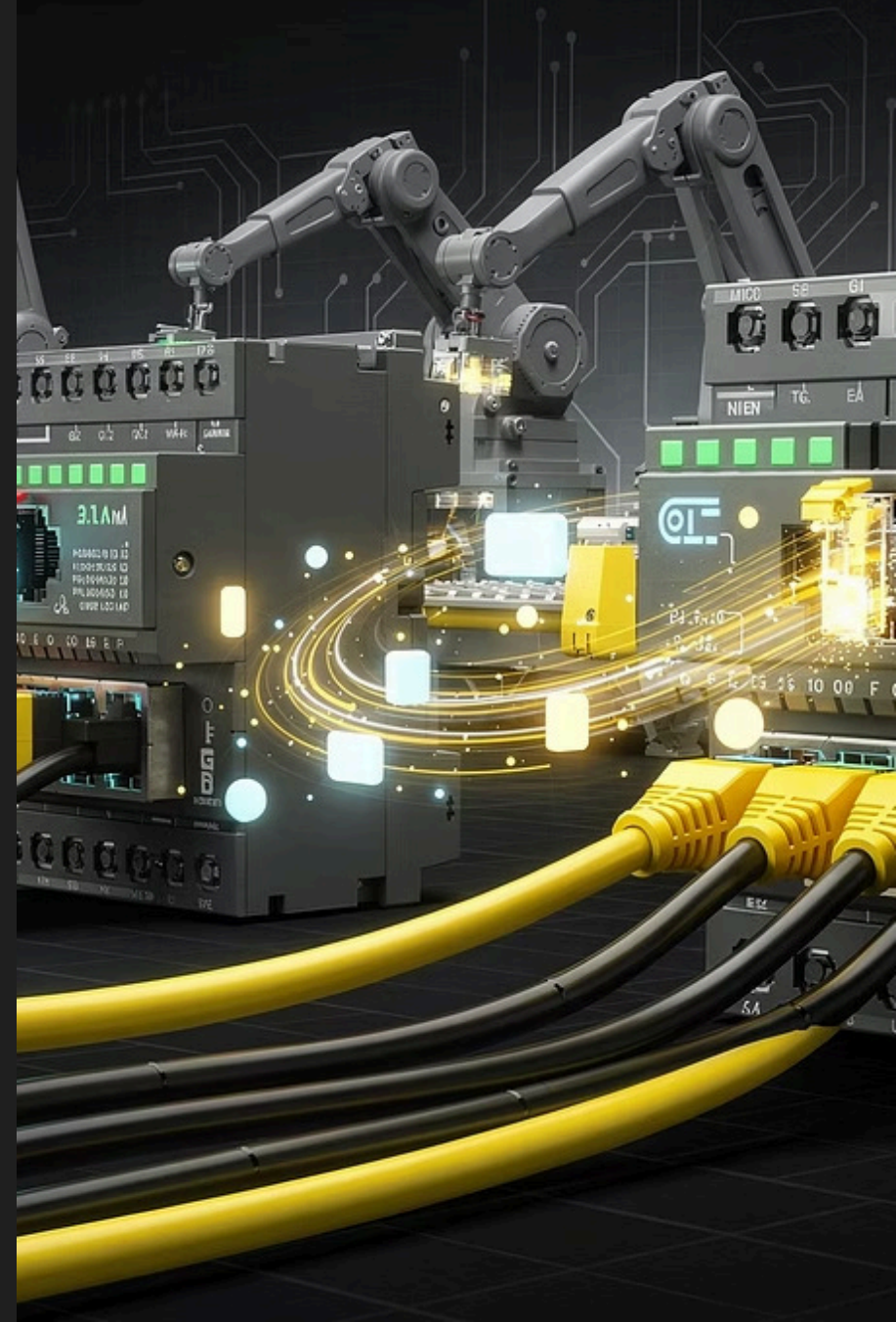
This can mean limited transparency, slower patching, and less ability to assess risk without vendor support.

Operational Constraints

Long equipment lifespans can leave critical assets running outdated software and insecure communications for decades.

Modbus TCP: The Least Common Denominator

Modbus TCP emerged as a prevalent protocol, enabling communication between industrial control systems from various vendors. Its simplicity and widespread adoption made it the de facto "least common denominator" for interoperability, often at the expense of robust security features inherent in its design.



Architecture as an Afterthought

ICS/OT environments are primarily engineered to fulfill specific operational functions, delivering on business objectives.

However, this intense focus on immediate operational goals often leads to foundational architectural planning, especially concerning security, being delayed or entirely overlooked until much later in the lifecycle.

Functional First Mentality

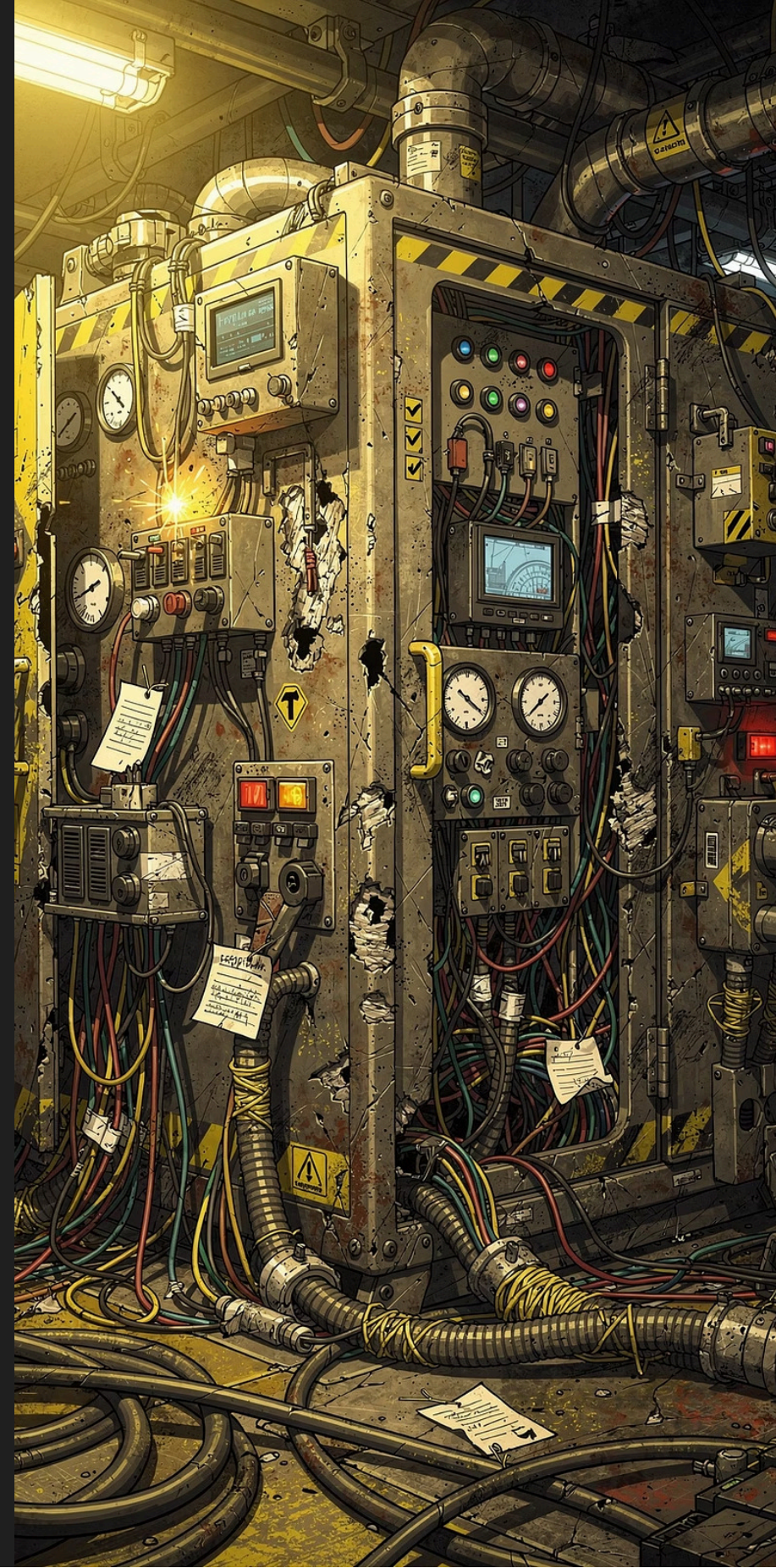
Design prioritizes operational uptime, reliability, and process control, often at the expense of integrated security architecture.

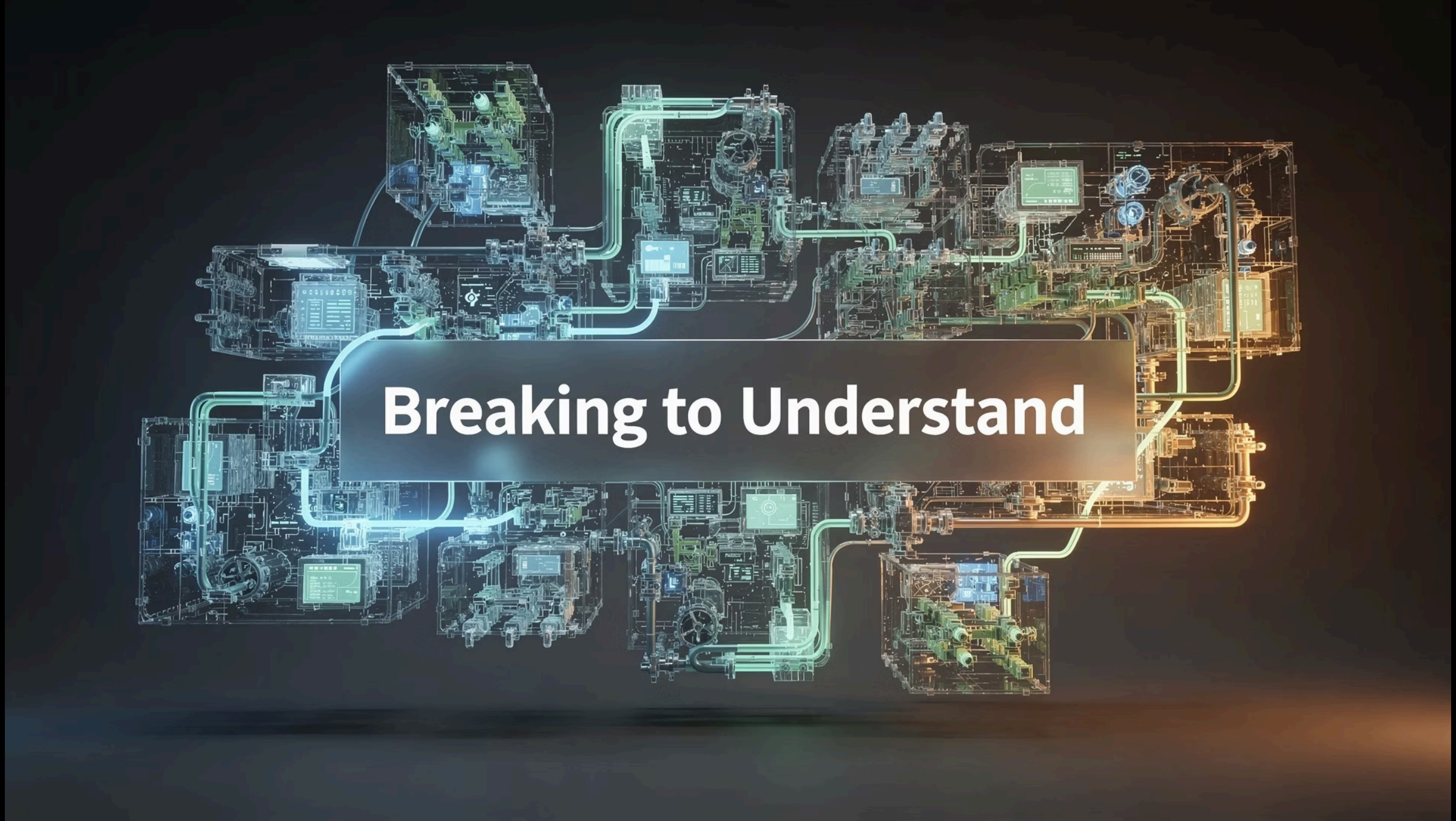
Reactive Security Measures

Security is commonly "bolted on" after deployment, resulting in complex, fragile, and often incomplete protections that can introduce new vulnerabilities.

Compounded Technical Debt

A lack of forethought leads to a spaghetti-like architecture, making future maintenance, upgrades, and effective security patching extremely challenging and costly.





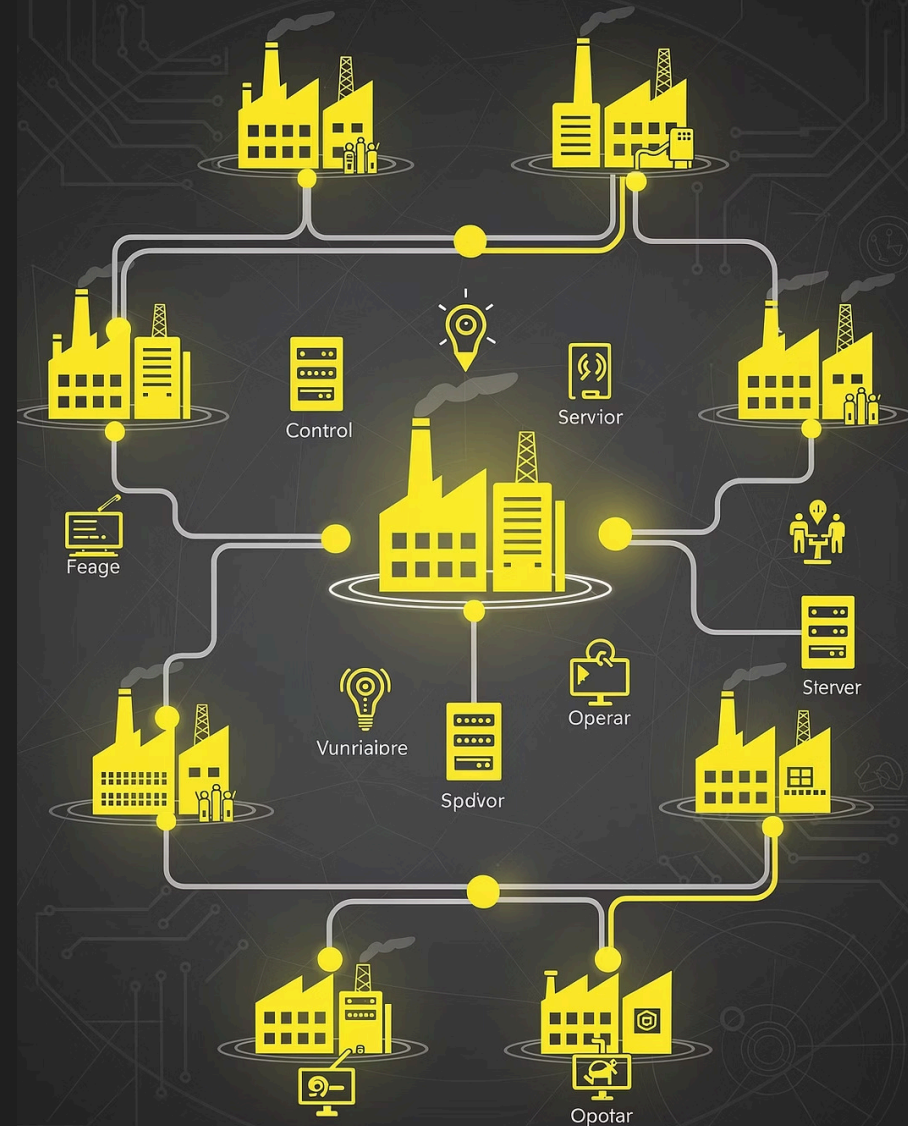
Breaking to Understand

Understanding the Attack Surface

Thinking Like an Adversary

Effective defense of critical infrastructure requires a deep understanding of potential attack vectors and their consequences. By analyzing how ICS/OT systems can be compromised, we can proactively fortify defenses and minimize operational risks.

- ① Only by understanding how systems can be broken, can we truly understand how to protect them.

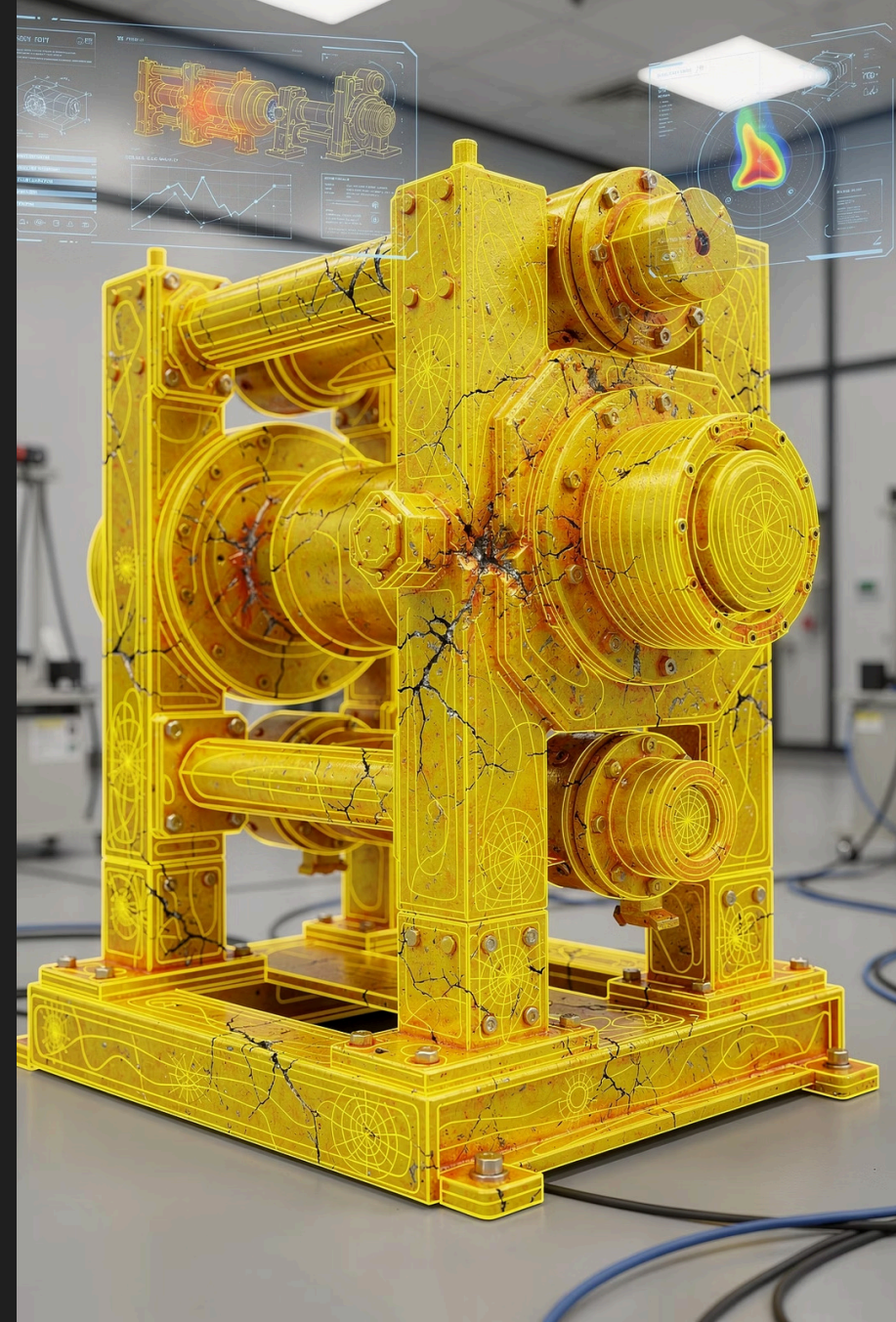


The Value of Destructive Testing

To truly understand and fortify complex ICS/OT environments, we must actively seek out their breaking points. Destructive testing provides invaluable insights into system resilience and reveals critical vulnerabilities before adversaries do.



Only by understanding how systems can be broken, can we truly understand how to protect them.





CJA – Weighing the value of Assets

Crown Jewels Analysis (CJA) identifies assets whose compromise produces the **highest operational consequence**.

Attacker Logic

Find the most consequential point that is the least defended. Context becomes the keys to the kingdom.

Defender Logic

CJA tells defenders where to prioritize — segmentation, monitoring, and IR resources go where impact is highest.

- ① Attackers do this analysis implicitly. Defenders should do it **explicitly**.



Steps to Produce a CJA

1 Define Mission / Objectives

Establish what the organization exists to do. Everything flows from this.

2 Identify Critical Functions

What capabilities must remain operational to fulfill the mission?

3 Map Assets to Functions

Systems, data, people, and processes that enable each critical function.

4 Prioritize Assets

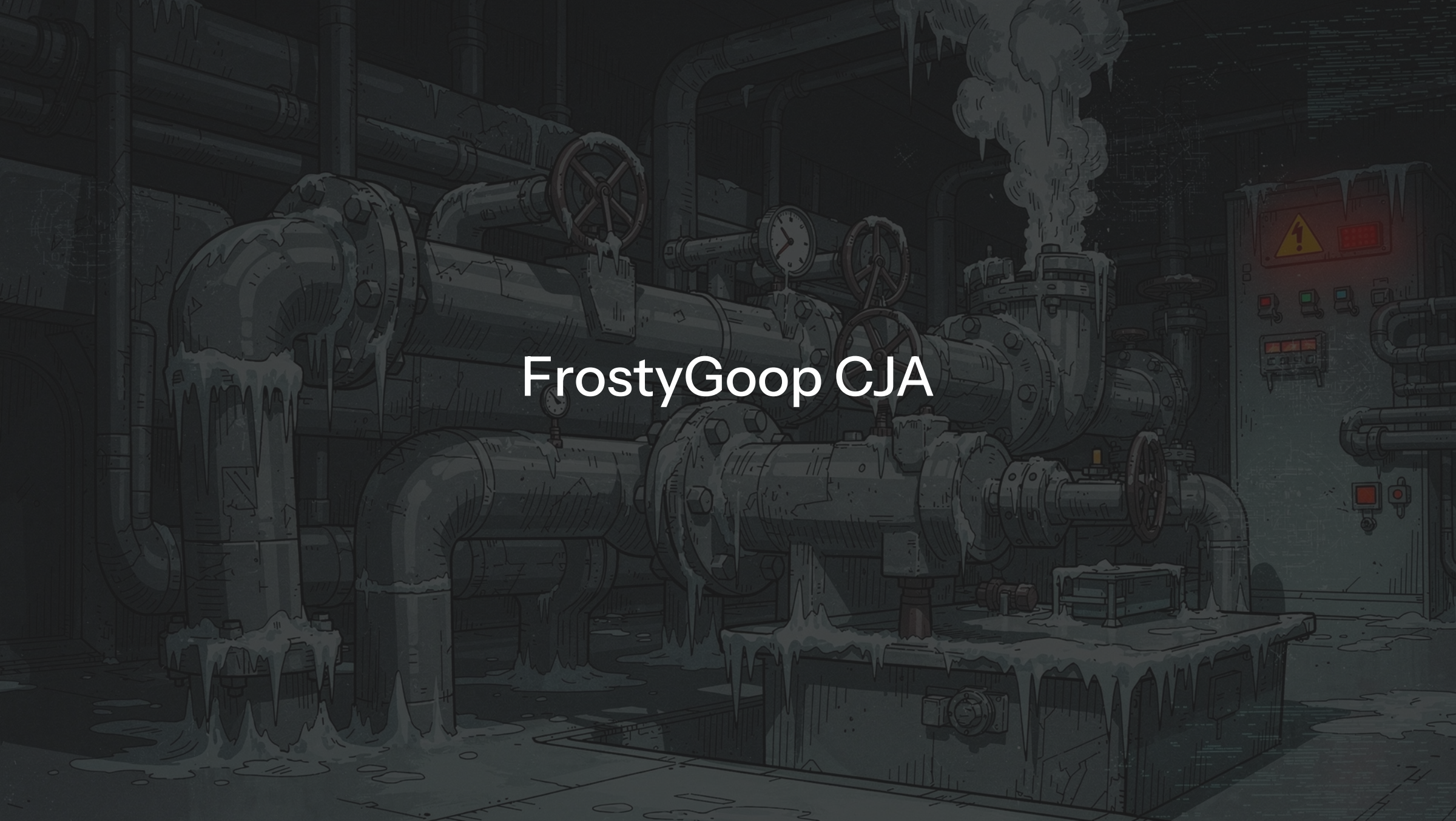
Rank by impact if compromised — this produces the crown jewels list.

5 Identify Dependencies

Upstream/downstream connections including third parties, shared infrastructure, and supply chain.

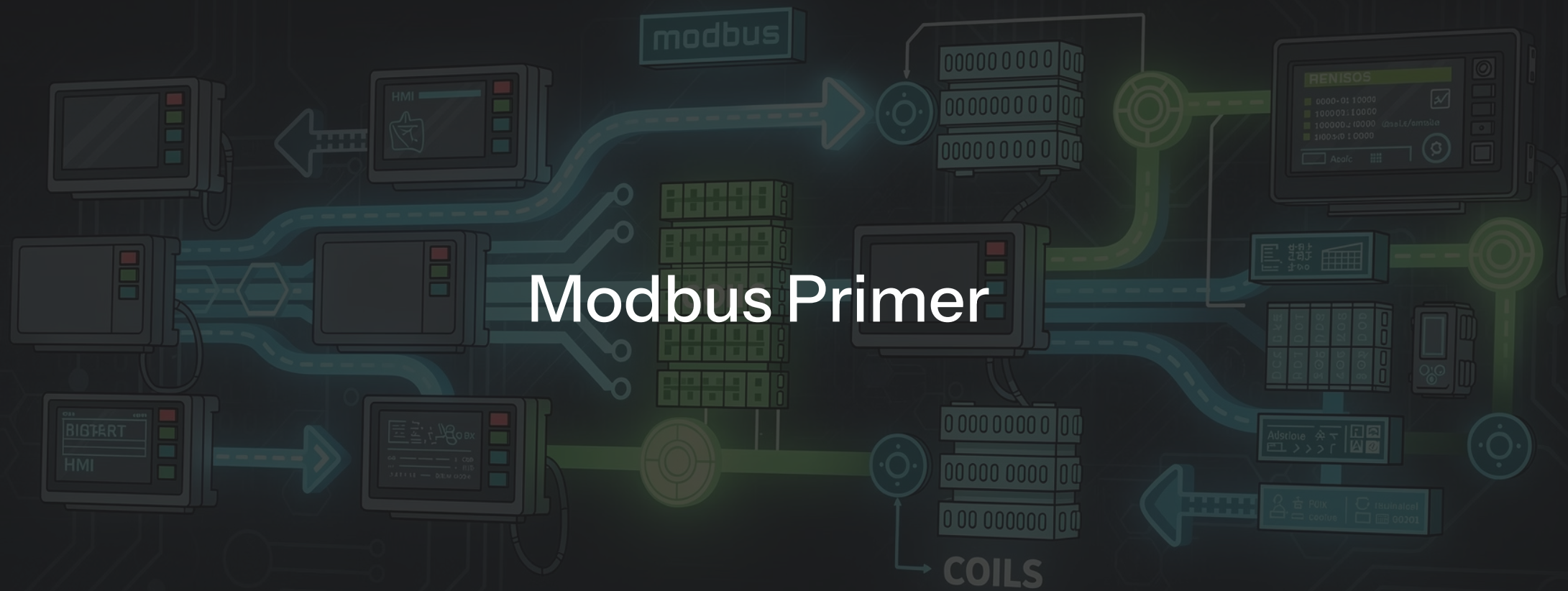
6 Assess Threat Exposure

For each crown jewel, identify realistic threat vectors and actors.

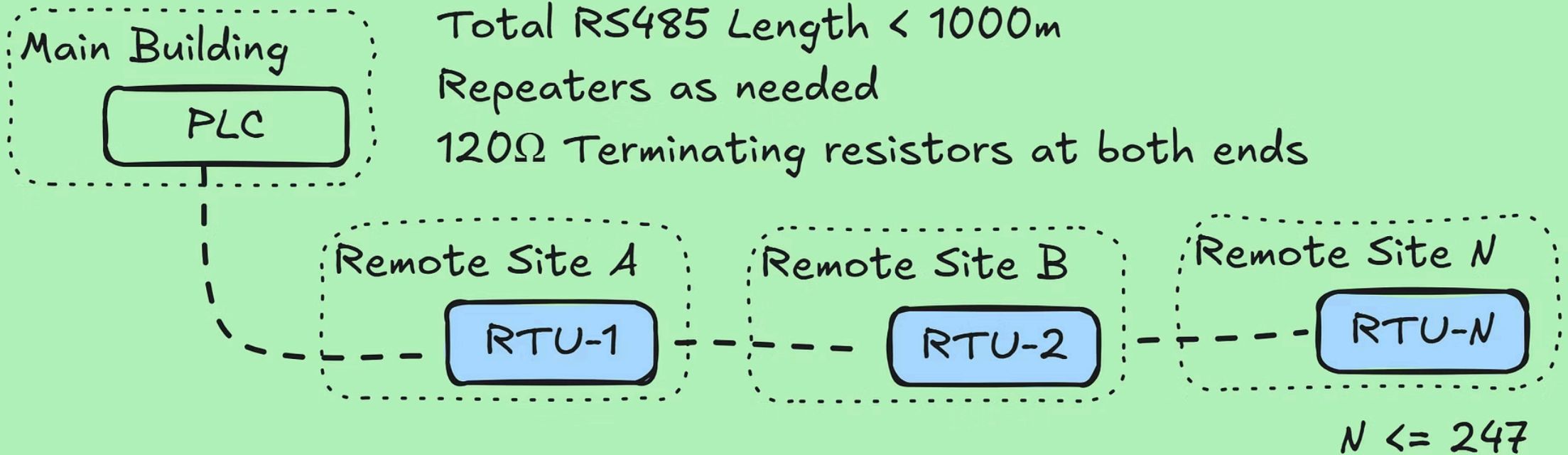


FrostyGoop CJA

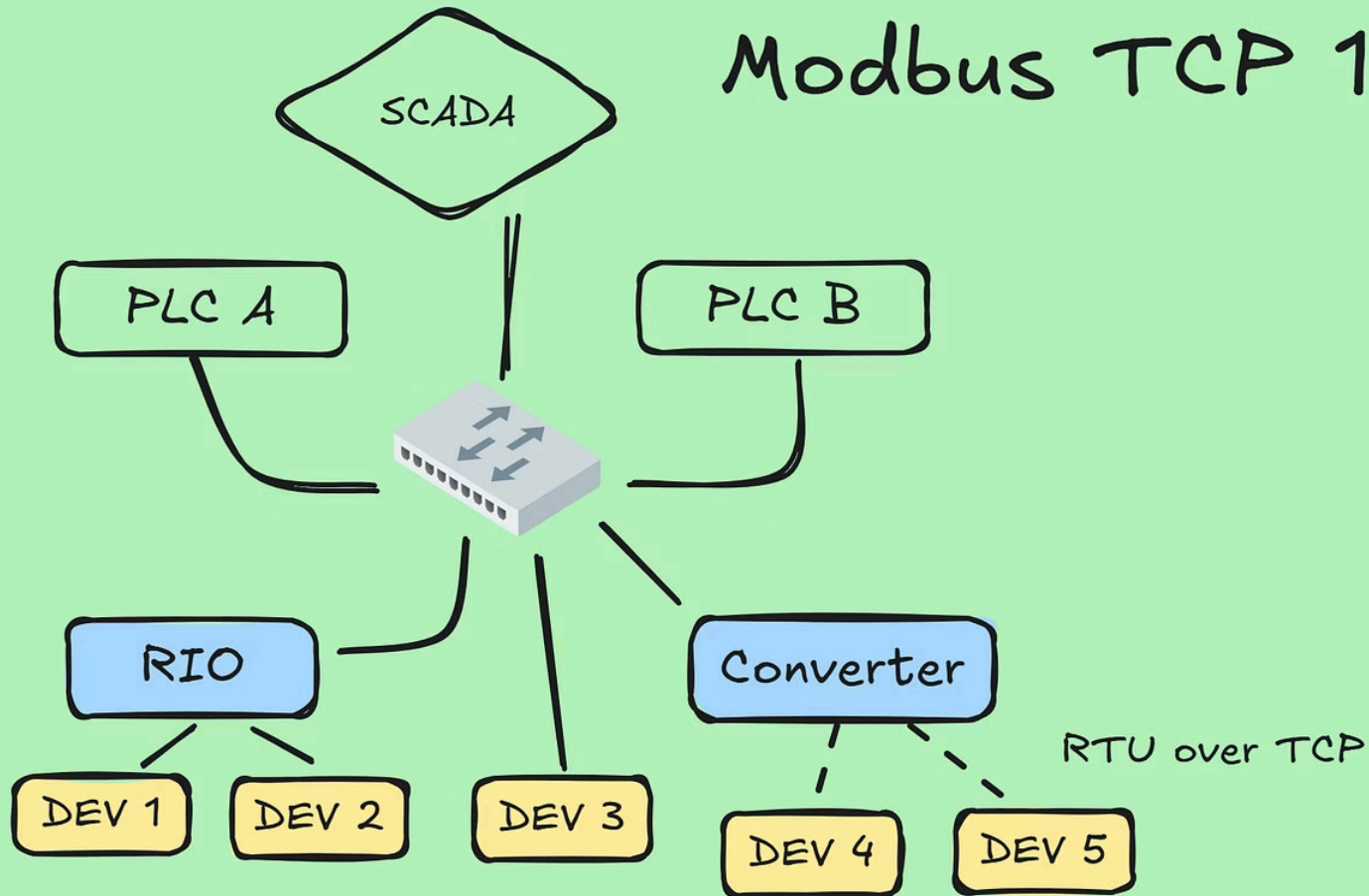
Modbus Primer



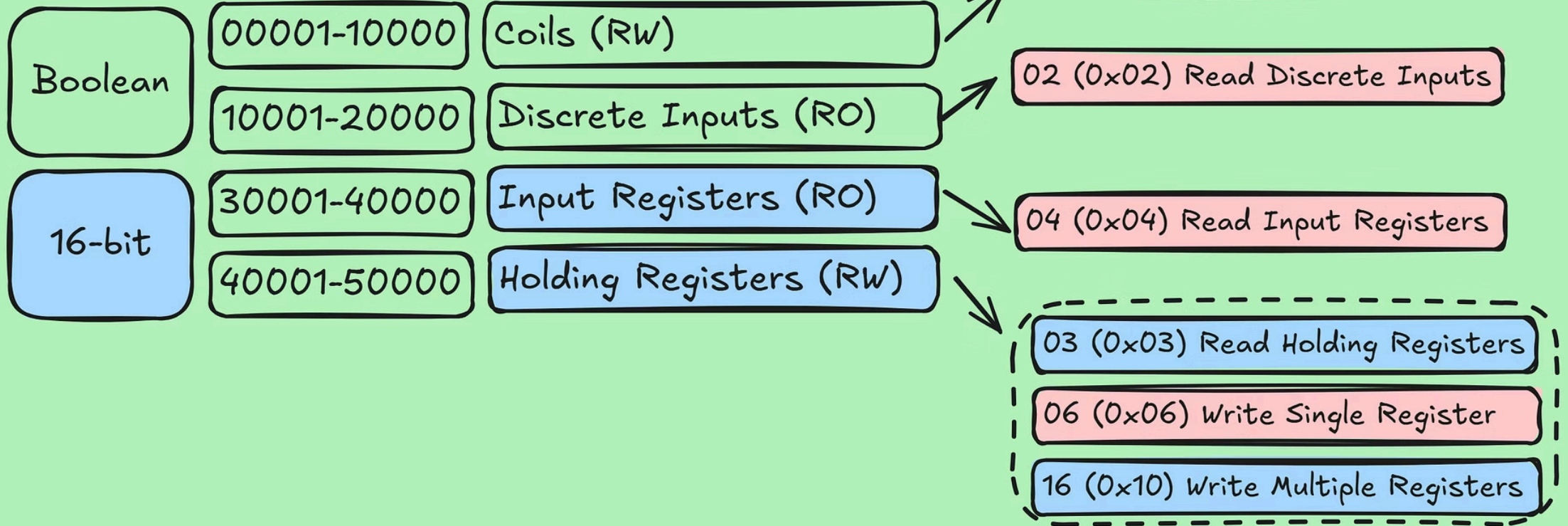
Modbus RTU (Serial) 1970s-1990s



Modbus TCP 1990s-Present



Modbus Data & Function Codes



4.0 Inverter Holding Registers Mapping

The MODBUS read function code is 0x03,and write function codes is 0x06.

4.1 Holding Registers Mapping(For remote scheduling)

Start	End	Size	R/W	Name	Type	CPS Units	Uint	Scale factor	Min value	Max value	Contents	Mode	Description
0x1000	0x1000	1	RW	OnOff	uint16	1	NULL	0	0x5555	0xAAAA	0x5555/ 0xAAAA	All	Device power on or off command. 0xAAAA power on, 0x5555 power off.
0x1001	0x1001	1	RW	PSet	uint16	0.1%	NULL	-3	0	1000	NULL	All	Remote electric dispatch Active Power setting value, range [0.0%,100.0%], E.g. 70.7%,then PSet =0x02c7.
0x1002	0x1002	1	RW	PFSet	int16	0.001	NULL	-3	-1000 -800	800 1000	NULL	All	Remote electric dispatch Power factor Setting, Range [-1.000,-0.800]U[0.800, 1.000], E.g. 0.931, then PFSet =0x0359, -0.931 PFSet =0xFC5D

System Recon — Context Is King

The Core Challenge

Decoding register meaning is the hardest part of Modbus. A 16-bit value could be a temperature, a boolean packed into bits, a high-word float, or an ASCII character. Without context, it's noise.

Two Paths to Context

OEM Equipment

Look up the vendor's published Modbus register map. Many are freely available in product manuals.

Integrator PLC

- Pull registers and decode manually.
- Compare live values against SCADA/HMI displays. Guess, check, and iterate.
- AI can accelerate pattern recognition on serialized data.

Example: OEM Register Map

 A published register map hands an attacker everything they need to write targeted payloads — no reverse engineering required.

4.1 Holding Registers Mapping(For remote scheduling)													
Start	End	Size	R/W	Name	Type	CPS Units	Uint	Scale factor	Min value	Max value	Contents	Mode	Description
0x1000	0x1000	1	RW	OnOff	uint16	1	NULL	0	0x5555	0xAAAA	0x5555/0xAAAA	All	Evilce power on or off command, 0xAAAA power on, 0x5555 power off.
0x1001	0x1001	1	RW	PSet	uint16	0.1%	NULL	-3	0	1000	NULL	All	Remote electric dispatch Active Power setting value, range [0.0%,100.0%], E.g. 70.7%,then PSet =0x02c3
0x1002	0x1002	1	RW	PFSet	int16	0.001	NULL	-3	-1000 -800	800 1000	NULL	All	Remote electric dispatch Power factor Setting, Rang [-1.000,-0.800]U[0.800, 1.000], E.g. 0.931, then PFSet =0X03A3; -0.931 PFSet =0xFC5D

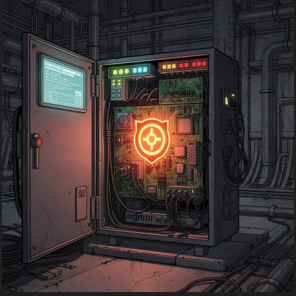
11 / 51

 There is a copy of example register maps in ModbusMaps\ in the cloned repo.



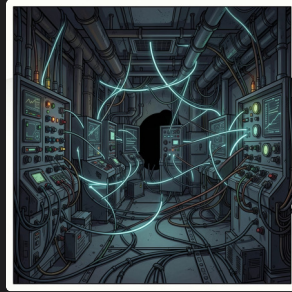
FrostyGoop Example

Key Takeaways from the FrostyGoop Incident



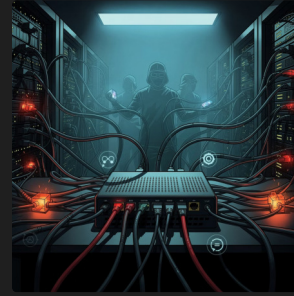
Unsecured Register Access

The heating controller's temperature register allowed both reading and writing, creating a critical vulnerability.



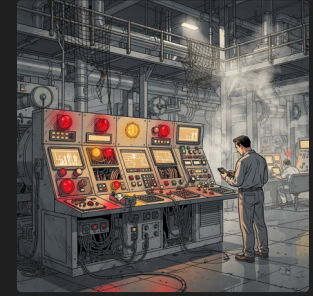
Lack of OT Traffic Monitoring

Absence of Modbus traffic oversight on the operational technology side of the MikroTik router meant anomalies went undetected.



Inadequate Outbound Connection Monitoring

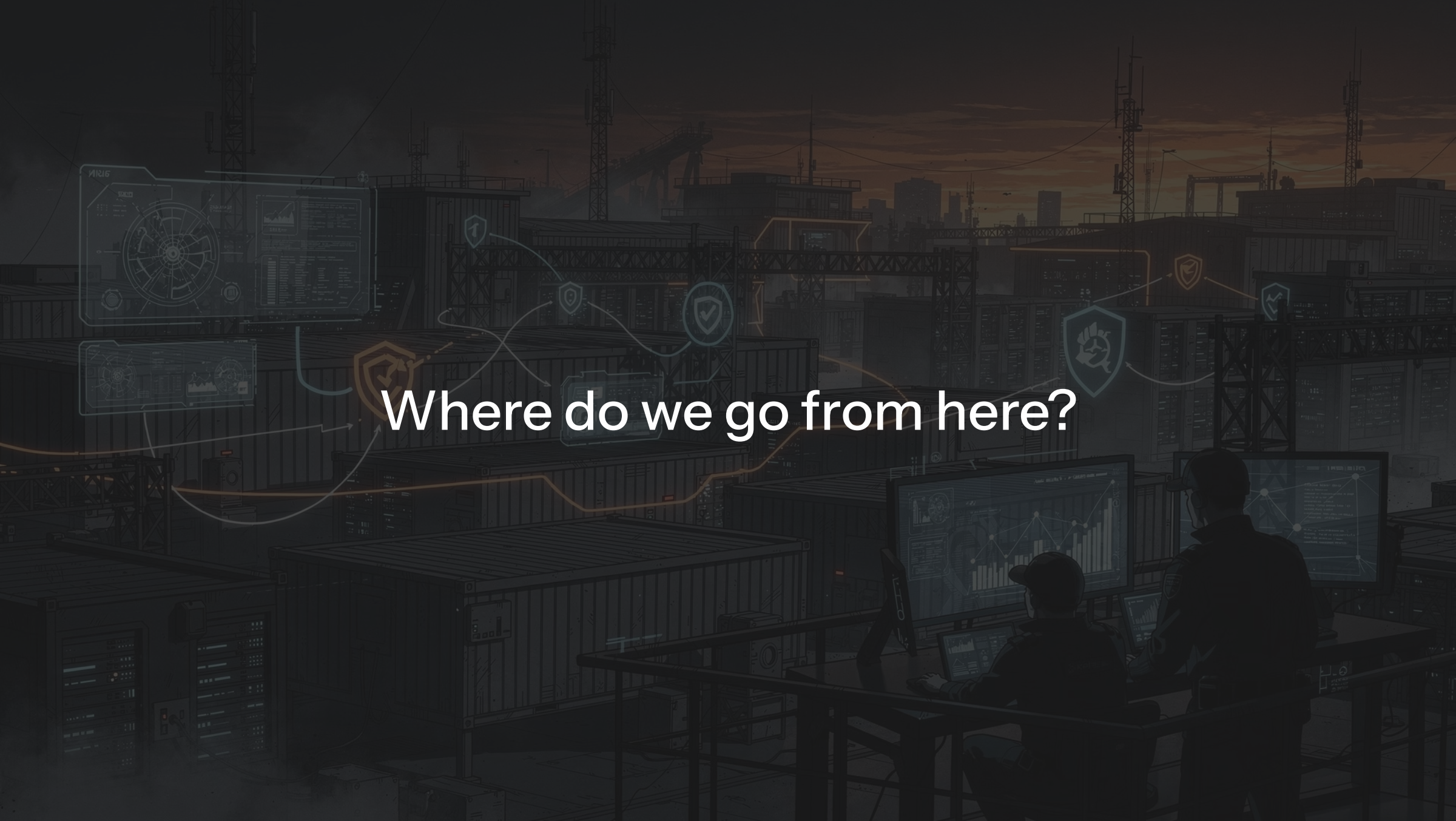
The MikroTik router lacked monitoring for outbound connections, enabling C2 & persistence.



Lack of failsafes or sanity checks

Is there another way to validate the system is working properly?

What other data points could be monitored?



Where do we go from here?

The background is a dark, atmospheric illustration of a server room or data center. In the foreground, two silhouetted figures are seated at a desk, working on multiple computer monitors displaying data charts and graphs. The room is filled with rows of server racks and storage units. Overlaid on the scene are several glowing, semi-transparent data visualizations, including circular radar-like charts and line graphs. A network of glowing lines and shield-shaped icons connects different parts of the scene, suggesting a complex data flow or security system. The overall color palette is dark, with muted blues, greys, and oranges, creating a high-tech, industrial feel.

Recurring Challenges in OT Security

These patterns often lead to significant security debt and vulnerability in critical infrastructure.



The "Just Make It Work" Trap

Security is often loosened during deployment to achieve functionality.

These temporary compromises frequently become permanent vulnerabilities, creating unmanaged risks.



The "Later" Illusion

The promise to harden systems "later" rarely materializes. Operational demands and budget constraints often prevent revisiting security, leaving systems exposed indefinitely.



Late-Stage Architecture

Delaying architectural security discussions until late in a project leads to reactive, inefficient, and often ineffective solutions, increasing costs and risks over time.

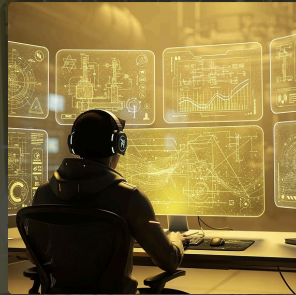
AI's Transformative Impact on ICS/OT Offense

Artificial Intelligence is rapidly reshaping the cybersecurity landscape, offering new advantages to adversaries targeting industrial control systems.



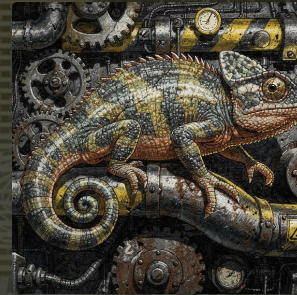
Accelerated Attack Cycles

AI-driven analysis identifies vulnerabilities and develops exploits faster, drastically shortening the window organizations have to patch or mitigate.



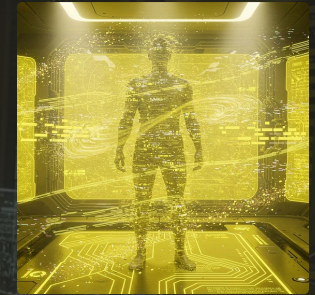
Enhanced Reconnaissance & Context

AI can rapidly process vast amounts of OT data, reverse-engineer proprietary protocols, and build detailed system models, providing attackers unprecedented contextual understanding.



Sophisticated Living Off The Land

AI enables adversaries to better leverage legitimate system tools and processes, making attacks blend seamlessly with normal operations and harder to detect.



Dynamic Evasion Techniques

AI can learn from defensive responses, dynamically adapt attack patterns, and generate polymorphic malware, increasing stealth and persistence against traditional security measures.



Questions?



The image depicts a person from behind, sitting at a desk in a dark, industrial control room. The person is looking at three computer monitors. The left monitor shows two yellow warning icons. The middle monitor displays a network diagram. The right monitor shows a list of text. Above the desk, several more monitors are mounted on the wall, displaying various data visualizations like bar charts, circular gauges, and network maps. The room is filled with complex machinery, cables, and two large, mechanical, humanoid figures on either side of the desk. The overall atmosphere is dark and high-tech.

Thank you!